PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Architectures et sécurité DNS

03-1040 ANSSI - Recommandations relatives aux architectures des services DNS — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Les services DNS internes et externes doivent être physiquement séparés sans aucun flux entre eux.
2. Le serveur primaire caché n'interagit qu'avec les serveurs secondaires et ne répond jamais aux clients.
3. L'utilisation d'un serveur tampon est recommandée pour l'intercalage entre le primaire caché et les secondaires hébergés à l'extérieur.

Services et fonctions DNS

Notion	À retenir
Trois services DNS	Le guide traite : **DNS-PRIV** (résolution noms internes), **DNS-PUB** (résolution noms Internet) et **DNS-HEB** (hébergement noms Internet).
Les fonctions DNS	Fonctions de base : **primaire** (souvent caché), **secondaire**, **cache**, **récursif**, **relais** et **tampon**.

Recommandations communes DNS

Notion	À retenir
Cloisonnement	Cloisonner **physiquement** les infrastructures **internes/externes** (interdire les flux entre elles), séparer les fonctions sur des **serveurs distincts** et filtrer les flux.
Primaire caché et transferts	Primaire **caché** pour maîtriser son exposition ; transferts de zone protégés en intégrité par **TSIG**, au niveau renforcé par **XoT**.
Durcissement	Renforcé : **diversifier les logiciels DNS** (une vulnérabilité ne touche pas tout) ; durcir les composants, **pare-feu local** actif.
DNSSEC	Contre l'**empoisonnement de cache** (réponses non signées rejetées) ; complément de **SPF, DKIM, DMARC, DANE**. Analyse de risque, gestion et supervision propres ; **validation activée** sur DNS-PUB.
Administration et exploitation	Administration sécurisée, processus de **MCS**, **journalisation centralisée**.

Recommandations par service

Service	À retenir
DNS-PRIV (noms internes)	Pas de résolution de noms Internet, **aucun accès depuis Internet** ; clients limités au **serveur cache** ; fonctions cloisonnées, flux filtrés.
DNS-PUB (noms Internet)	Pas d'accès depuis Internet ; **serveur relais**, cache cloisonné physiquement et **en coupure** d'Internet ; listes d'interdiction (renforcé : **listes d'autorisation**) ; limiter les requêtes par client.
DNS-HEB (hébergement)	Primaire caché + secondaires + **tampon** ; protection **anti-DDoS**, serveurs cloisonnés physiquement ; tampon pour les secondaires externes, primaire caché coupé d'Internet, secondaires **en coupure** ; mises à jour sur le primaire, propagées par transfert de zone.

Pièges et confusions

- ⚠ Croire que des flux peuvent exister entre les services DNS internes et externes
- ⚠ Penser que le serveur primaire répond directement aux clients
- ⚠ Oublier que les transferts de zone doivent être protégés par TSIG ou XoT
- ⚠ Ignorer que DNSSEC nécessite une analyse de risque et une supervision dédiés
- ⚠ Croire que les clients internes peuvent interroger d'autres serveurs que le serveur cache

Sigles et définitions

DNS	système qui traduit les noms de domaine en adresses et en autres informations techniques
Serveur faisant autorité	répond aux requêtes pour les zones placées sous son autorité sans faire appel à d'autres serveurs
TSIG	mécanisme d'authentification des transactions DNS par clé partagée
XoT	transfert de zone protégé par TLS
DNSSEC	extension de sécurité du DNS garantissant l'intégrité et l'authenticité des réponses par une chaîne de signatures
Empoisonnement de cache	injection de fausses réponses dans le cache d'un serveur pour détourner les utilisateurs

Auto-test

1. Quel mécanisme protège le transfert de zone par TLS ?
2. Quelle fonction DNS stocke les réponses pour répondre plus vite aux suivantes ?
3. Comment appelle-t-on l'injection de fausses réponses dans un cache ?
4. Quel serveur parcourt la hiérarchie DNS s'il ne connaît ni la réponse ni le serveur faisant autorité ?
5. Que garantit DNSSEC ?

Réponses : **1.** XoT · **2.** Le serveur cache · **3.** L'empoisonnement de cache · **4.** Le serveur récursif · **5.** L'intégrité et l'authenticité des réponses

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.